

Implantación de seguridad perimetral

Seguridad y Alta Disponibilidad

Qué es un perímetro de red informático?

Un perímetro de red (o perímetro informático) define la línea que separa la intranet local y privada de una empresa con la del mundo público y exterior, más conocida como "Internet". Este límite es muy importante si se quiere mantener la información y los recursos confidenciales fuera del alcance del público en general y, obviamente, de las personas maliciosas en particular.

Qué es la seguridad perimetral informática?

- La seguridad perimetral informática es el proceso mediante el cual se asegura el perímetro de una red a través de la implementación de una combinación de software, dispositivos, técnicas y directrices.
- Algunas estrategias o directrices utilizadas dentro de la seguridad del perímetro informático pueden incluir la vigilancia pasiva o activa, la detección de amenazas y el análisis de patrones.
- Es importante entender que la seguridad perimetral informática es un proceso en constante evolución

Por qué es importante el perímetro de seguridad informática?

- **Primer punto de defensa:** El perímetro de una red es la “frontera” entre la infraestructura interna confiable y el exterior (Internet u otras redes menos seguras). Una protección sólida en ese punto evita que amenazas conocidas (como malware, ataques de fuerza bruta o intentos de acceso no autorizado) lleguen al núcleo de la organización.

Por qué es importante el perímetro de seguridad informática?

- **Reducción de riesgos y costos:** Al bloquear ataques desde el principio, se evita que estos se propaguen internamente, lo que puede ahorrar tiempo, dinero y recursos que de otra forma se invertirían en recuperación de datos, restauración de sistemas, multas por incumplimiento regulatorio o daños a la reputación de la empresa.

Por qué es importante el perímetro de seguridad informática?

- **Cumplimiento normativo y protección de datos sensibles:**
Muchas normativas de seguridad y privacidad exigen controles perimetrales mínimos. Cumplir con estos estándares contribuye a la protección de información confidencial, evita sanciones y mejora la confianza de clientes, socios y usuarios.

Por qué es importante el perímetro de seguridad informática?

- **Visibilidad y control del tráfico:** Herramientas como cortafuegos, IDS/IPS y pasarelas seguras brindan la capacidad de monitorear y filtrar el tráfico entrante y saliente. Esto permite conocer qué entra y qué sale de la red, bloqueando actividades sospechosas y detectando patrones anómalos a tiempo.

Cómo funciona la seguridad perimetral

- Un sistema de seguridad perimetral persigue establecer una barrera alrededor de una instalación de una empresa para poder controlar de forma más eficiente los accesos a las mismas. Un sistema perimetral realiza distintas funciones muy valiosas en materia de seguridad

Cómo funciona la seguridad perimetral

- Prevención y detección.
- Monitorizan un perímetro de seguridad alrededor de un sistema para prevenir que personas no autorizadas lo traspasen (actuación disuasoria) y para detectar cualquier intrusión de forma inmediata.
- Ganar tiempo.
- Con un buen sistema de seguridad perimetral, se consigue ganar tiempo para que el equipo de seguridad pueda actuar de forma eficiente ante incidentes o problemas de accesos no autorizados.
- Evaluación.
- La seguridad perimetral permite implementar un sistema de seguridad que permita evaluar la situación de una propiedad de forma mucho más sencilla y eficiente (gracias a elementos de seguridad perimetral como las barreras, los sensores o las cámaras CCTV, por ejemplo).

Componentes de la seguridad perimetral

- **Firewall (Cortafuegos):** Dispositivo o servicio que filtra el tráfico entrante y saliente basado en reglas predefinidas (permitir, denegar, registrar).
- **Sistemas de Detección y Prevención de Intrusiones (IDS/IPS):** Herramientas que analizan el tráfico en busca de patrones maliciosos; el IDS alerta, el IPS puede bloquear el ataque en tiempo real.
- **Pasarelas seguras (Secure Web Gateway / SWG):** Filtran el tráfico web, bloquean sitios maliciosos, analizan contenido, y aplican políticas de uso aceptable.

Componentes de la seguridad perimetral

- **VPN (Redes Privadas Virtuales):** Aseguran la conexión de usuarios remotos al perímetro mediante canales cifrados.
- **Sistemas anti-malware perimetrales:** Soluciones que analizan el tráfico en la puerta de entrada para detectar y bloquear virus, troyanos y otro software malicioso.
- **Reverse Proxy y balanceadores de carga:** Fungen como intermediarios para optimizar tráfico, esconder infraestructura interna y agregar una capa adicional de filtrado y autenticación.

Componentes de la seguridad perimetral

- Honypots: son parte de un concepto más amplio llamado "honeypots". Un honeypot es una trampa de seguridad diseñada para atraer y detectar a los atacantes cibernéticos. Los honeypots simulan ser sistemas informáticos vulnerables o recursos valiosos para atraer a los atacantes y observar sus métodos y tácticas.

Clasificación - Según su funcionalidad principal

Firewalls (Cortafuegos)

- **Cortafuegos de filtrado de paquetes:** Analizan el encabezado del paquete (dirección IP, puerto, protocolo) y aplican reglas estáticas para permitir o denegar el tráfico. Operan en niveles inferiores del modelo OSI (generalmente en la capa 3/4).
- **Cortafuegos de estado (Stateful Firewall):** Mantienen un seguimiento del estado de las conexiones, recordando el contexto del tráfico. Son más inteligentes que los de filtrado de paquetes, ya que pueden decidir en función de si el tráfico forma parte de una conexión existente o es un nuevo intento de conexión.
- **Cortafuegos de aplicación (Application Firewall o Proxy Firewall):** Operan a nivel de la capa de aplicación (OSI capa 7), inspeccionando el contenido del tráfico. Pueden filtrar en función de la lógica de la aplicación, no solo de puertos y direcciones IP.
- **Next-Generation Firewalls (NGFW):** Integran funcionalidades avanzadas, como inspección profunda de paquetes (DPI), prevención de intrusiones (IPS), control de aplicaciones y análisis heurístico o basado en comportamiento.

Clasificación - Según su funcionalidad principal

Sistemas de Detección y Prevención de Intrusiones (IDS/IPS)

- **IDS (Intrusion Detection System):** Monitorea el tráfico en busca de patrones o comportamientos sospechosos. Si detecta una posible amenaza, genera alertas, pero no bloquea por sí mismo el tráfico.
- **IPS (Intrusion Prevention System):** Además de detectar, puede tomar acciones para prevenir la intrusión, bloqueando el tráfico malicioso automáticamente.

Clasificación - Según su funcionalidad principal

Gateways y Proxies Específicos

- **Secure Web Gateway (SWG):** Analiza y filtra el tráfico web saliente y entrante. Bloquea sitios maliciosos, implementa filtros URL, inspecciona contenido y aplica políticas de acceso a Internet.
- **Proxies de correo electrónico (Mail Gateway):** Filtran el tráfico SMTP entrante y saliente, bloqueando spam, phishing y malware.
- **Web Application Firewall (WAF):** Diseñado para proteger aplicaciones web. Opera en la capa de aplicación y puede detectar y bloquear ataques como inyección SQL, cross-site scripting (XSS), etc.

Clasificación - Según su ubicación y modo de despliegue

- **Sistemas en el perímetro externo:**
Se colocan entre la red interna y la red pública (Internet) para controlar el tráfico que entra y sale. Por ejemplo, firewalls fronterizos.
- **Sistemas en el perímetro interno o segmentación interna:**
Controlan el tráfico entre diferentes subredes internas (microsegmentación), evitando que una brecha en una zona se extienda a toda la organización.

Clasificación - Según el enfoque de análisis

- **Basados en firma:**
Detectan patrones conocidos de ataques o malware basados en una base de datos de firmas. Son útiles contra amenazas conocidas, pero menos efectivos contra variantes nuevas o desconocidas.
- **Basados en comportamiento o heurística:**
Analizan el tráfico y comportamientos anómalos para detectar amenazas “zero-day” o ataques que no coincidan con firmas conocidas.

Clasificación - Según la capa del modelo OSI donde operan

- **Capa de Red y Transporte (L3/L4):**
Sistemas de filtrado de paquetes y stateful firewalls que trabajan en base a IP, puertos y protocolos.
- **Capa de Aplicación (L7):**
Firewalls de aplicación, WAF, proxies avanzados que analizan el contenido y la lógica de las comunicaciones.



Políticas de defensa perimetral

- Las políticas de defensa perimetral es establecer un conjunto de normas, criterios y procedimientos destinados a proteger la frontera entre la red interna (considerada segura o de confianza) y la red externa (generalmente Internet, considerada no segura).

Objetivo de las políticas de seguridad perimetral

- **Reducir las posibilidades del atacante:** Configurando cuidadosamente qué tráfico se permite y qué tráfico se bloquea, se limita la superficie de ataque. Es decir, al controlar estrictamente qué servicios y puertos están disponibles desde el exterior, se dificulta que un atacante encuentre vulnerabilidades.
- **Minimizar los daños causados por el atacante:** En el caso de que un intruso logre penetrar la primera capa de defensa, las medidas perimetrales (como cortafuegos, IDS/IPS, proxies, segmentación de la red, etc.) ayudan a contener y limitar el impacto del ataque, impidiendo que se propague o acceda fácilmente a todos los recursos internos.

Servidores de autenticación

- Estos servidores (a menudo llamados servidores AAA: Autenticación, Autorización y Accounting) son sistemas centrales que validan las credenciales de un usuario que intenta acceder a una red o a un recurso en particular. No solo comprueban la identidad del usuario (autenticación), sino que también determinan a qué servicios y recursos puede acceder (autorización) y registran las actividades realizadas (accounting), facilitando la auditoría y el seguimiento del uso de la red.

Protocolos AAA más conocidos

- **Protocolos AAA más conocidos:**
- **RADIUS (Remote Authentication Dial-In User Service):**
Protocolo ampliamente utilizado para autenticar y autorizar usuarios en redes, especialmente en entornos inalámbricos (WPA-Enterprise) o VPN. Trabaja habitualmente sobre UDP y se integra con bases de datos internas (LDAP, Active Directory) para verificar credenciales.
- **Diameter:**
Diseñado como sucesor de RADIUS, es un protocolo más robusto y escalable, con capacidad para autenticación y autorización de servicios de red complejos (redes móviles, VoIP) y cifrado con TLS o IPsec. Funciona en un esquema peer-to-peer, lo que aporta mayor flexibilidad.
- **TACACS/TACACS+:**
Asociado inicialmente con Cisco, TACACS+ separa las funciones AAA de forma granular, permitiendo una administración más detallada de permisos. A diferencia de RADIUS, normalmente usa TCP, lo que facilita una comunicación más confiable y cifrada integralmente.

Protocolos AAA más conocidos

- **LDAP (Lightweight Directory Access Protocol):**
No es un protocolo AAA puro, pero se integra frecuentemente en entornos de autenticación, ya que actúa como un directorio centralizado donde se almacenan usuarios, contraseñas y atributos asociados a la cuenta. Puede utilizarse como backend para RADIUS u otros servicios, ofreciendo una fuente unificada de información de identidad.
- **Kerberos:**
Utilizado principalmente en entornos basados en Windows y Unix, Kerberos ofrece autenticación fuerte mediante tickets cifrados. De este modo, las contraseñas nunca se transmiten en claro a través de la red. El usuario obtiene un “ticket” de autenticación del servidor Kerberos, que luego utiliza para acceder a otros recursos sin necesidad de enviar la contraseña repetidamente.

Aplicaciones de estos protocolos

- **Redes Wifi Empresariales (WPA-Enterprise):**
En lugar de usar una clave compartida para todos (PSK), se utiliza un servidor RADIUS para que cada usuario se autentique con sus propias credenciales. Esto aporta mayor seguridad y control sobre quién se conecta y bajo qué condiciones.

Aplicaciones de estos protocolos

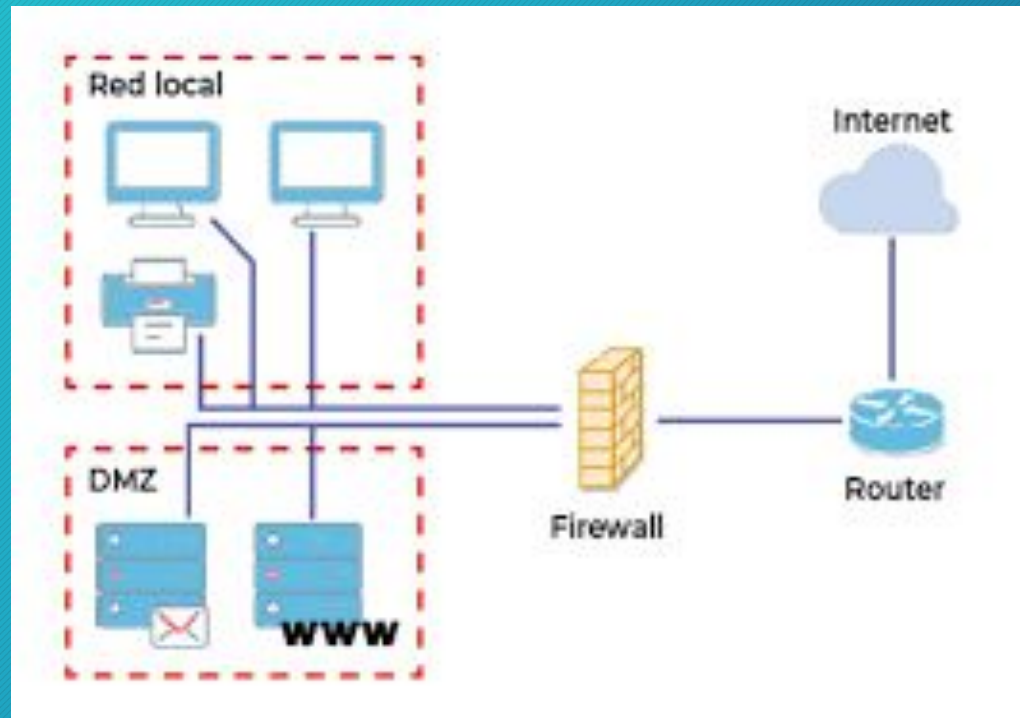
- **Acceso a VPN y Recursos Corporativos:**
Cuando un empleado se conecta de forma remota, se utiliza un servidor de autenticación (RADIUS, LDAP, Kerberos) para validar su identidad y determinar qué partes de la red puede utilizar.
- **Sistemas de acceso a aplicaciones y servicios internos:**
Un servidor AAA puede controlar el acceso a aplicaciones web corporativas, bases de datos y otros sistemas, garantizando que cada usuario solo vea y use lo que se le ha autorizado.

Arquitecturas de seguridad perimetral

- **Control del tráfico saliente y entrante:** Decidir qué conexiones están permitidas desde y hacia la red interna.
- **Clasificación del tráfico:** Separar y categorizar el tipo de tráfico según su origen, destino, protocolo y contenido, aplicando así políticas de seguridad diferenciales.
- **Denegación de conexiones no autorizadas:** Bloquear por defecto todo lo que no esté expresamente permitido, minimizando la superficie de ataque.

Zona desmilitarizada DMZ

- Una zona desmilitarizada (demilitarized zone, DMZ) es una red perimetral que protege la red de área local (local-area network, LAN) interna contra el tráfico no confiable.

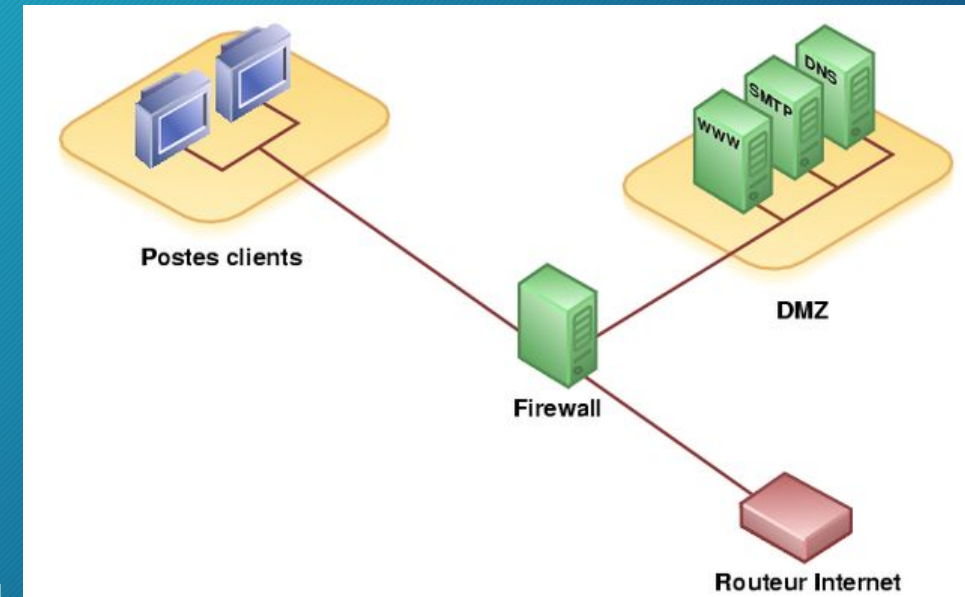


DMZ - Arquitectura débil de subred protegida

Este tipo de arquitectura también se conoce como “single firewall architecture”. Básicamente, se coloca un único firewall que tiene al menos tres interfaces:

- **Interfaz externa:** Conectada a Internet.
- **Interfaz interna:** Conectada a la red interna (confiable).
- **Interfaz DMZ:** Conectada a la zona desmilitarizada.

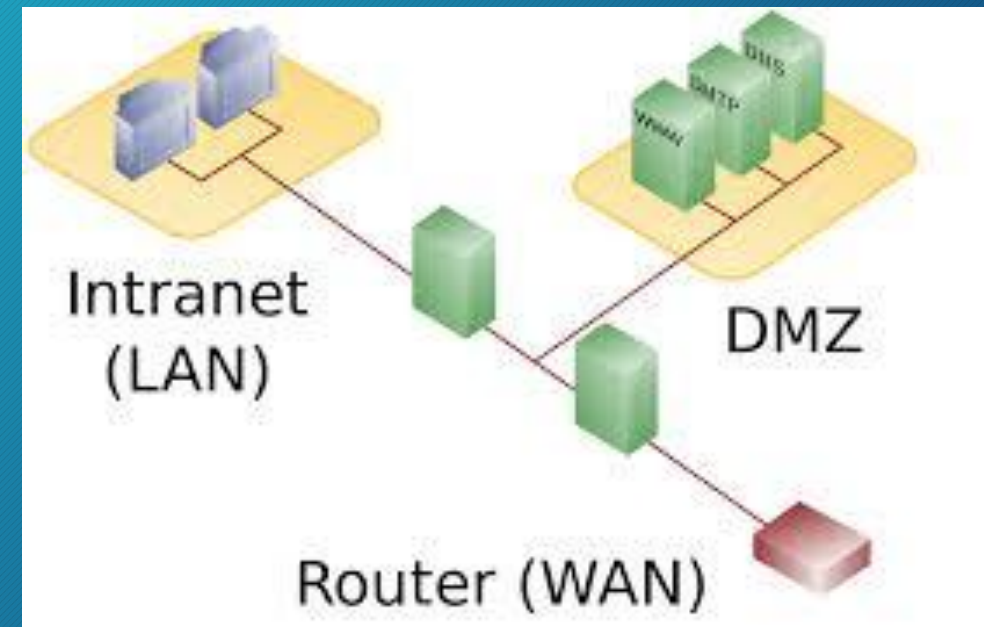
Punto débil: Si el firewall falla o es vulnerado, existe un mayor riesgo, ya que toda la seguridad depende de un único dispositivo que separa tanto la DMZ como la red interna del exterior. Además, si las políticas no están bien configuradas, la DMZ podría no ofrecer una separación tan fuerte de la red interna.



DMZ - Arquitectura fuerte de subred protegida

- **Firewall perimetral externo:** Situado entre Internet y la DMZ. Este primer firewall controla el tráfico hacia los servidores públicos, reduciendo el riesgo y la carga en el firewall interno.
- **Firewall interno o “trasero”:** Ubicado entre la DMZ y la red interna. Garantiza que, incluso si un servidor de la DMZ es comprometido, el atacante no pueda penetrar fácilmente hacia la red interna sin sortear esta segunda barrera.

Ventaja principal: La arquitectura fuerte crea una defensa en profundidad, dificultando que el compromiso de la DMZ resulte en acceso inmediato a la red interna. También facilita la distribución de funciones de seguridad entre varios dispositivos, reduciendo la dependencia de un único punto de fallo.



Seguridad Perimetral en la Nube

- La seguridad perimetral en la nube se refiere a la protección de los recursos y los datos que se encuentran alojados en servidores remotos accesibles mediante Internet, y que son utilizados por las organizaciones para agilizar sus operaciones. La seguridad perimetral en la nube implica el uso de diferentes medidas y tecnologías, como los firewalls, las redes virtuales privadas (VPN), los sistemas de detección y prevención de intrusiones (IDS/IPS), los controles de acceso e identidad, o los sistemas anti-DDoS. Estas medidas tienen como objetivo restringir o controlar el tráfico que entra o sale de los recursos en la nube, así como detectar y bloquear las amenazas o los ataques que provienen de Internet o de otras redes externas.

Clasificación de zonas de riesgo LAN

- Zona interna: es la zona más segura de la red, donde se ubican los recursos y servicios más críticos y confidenciales de la organización, como los servidores de bases de datos, los sistemas de gestión, los archivos, etc. Esta zona tiene acceso restringido y controlado a los usuarios autorizados, y se protege mediante firewalls, sistemas de detección y prevención de intrusiones, controles de acceso e identidad, cifrado de datos, etc.
- Zona desmilitarizada (DMZ): es una zona intermedia entre la zona interna y la zona externa, donde se ubican los recursos y servicios que deben ser accesibles desde el exterior, pero que tienen acceso limitado a la zona interna, como el servidor web, el de correo, el de acceso remoto, etc. Esta zona se aísla mediante firewalls u otros dispositivos de seguridad que filtran el tráfico entre la DMZ y la zona interna o externa. El objetivo de la DMZ es reducir el riesgo de que un atacante pueda acceder a los recursos de la zona interna desde el exterior.
- Zona externa: es la zona más expuesta de la red, donde se ubican los recursos y servicios que se conectan directamente a Internet o a otras redes públicas, como los routers, los módems, los proxies, etc. Esta zona tiene acceso abierto y no controlado a los usuarios externos, y se protege mediante firewalls, sistemas anti-DDoS, honeypots, etc.

Clasificación de zonas de riesgo WAN

- Zona segura: es la zona donde se ubican las redes locales de las diferentes sedes o sucursales de la organización, que se interconectan mediante una red privada virtual (VPN) que garantiza la seguridad, la confidencialidad y la integridad de las comunicaciones entre ellas. Esta zona se protege mediante firewalls, sistemas de detección y prevención de intrusiones, controles de acceso e identidad, cifrado de las comunicaciones, etc.
- Zona insegura: es la zona donde se ubican los recursos y servicios que se conectan a Internet o a otras redes públicas, como los routers, los módems, los proxies, etc. Esta zona tiene acceso abierto y no controlado a los usuarios externos, y se protege mediante firewalls, sistemas anti-DDoS, honeypots, etc.

Clasificación de zonas de riesgo WLAN

- Zona segura: es la zona donde se ubican los recursos y servicios que se conectan a la red inalámbrica mediante un punto de acceso que implementa protocolos de seguridad, como WPA2, que garantizan la seguridad, la confidencialidad y la integridad de las comunicaciones entre ellos. Esta zona se protege mediante firewalls, sistemas de detección y prevención de intrusiones, controles de acceso e identidad, cifrado de las comunicaciones, etc.
- Zona insegura: es la zona donde se ubican los recursos y servicios que se conectan a la red inalámbrica mediante un punto de acceso que no implementa protocolos de seguridad, o que los implementa de forma débil, como WEP, que no garantizan la seguridad, la confidencialidad y la integridad de las comunicaciones entre ellos. Esta zona tiene acceso abierto y no controlado a los usuarios externos, y se protege mediante firewalls, sistemas anti-DDoS, honeypots, etc.

DMZ



DMZ DE UNA VEZ

NW